

Software Images with verification mechanisms built in MAY be transported over insecure communication mechanisms while still maintaining their authenticity and integrity. In fact, it is likely that the originator of the Software Image (a Vendor) will not be directly connected to any Fabric and therefore distribute the Software Image across other mediums (such as the Internet) before arriving on the Fabric. Therefore, it is crucial that the Software Image verification be independent of the communication medium. Any attempts to tamper with the signature or the data itself SHALL be detected and SHALL cause the Software Image to be rejected by the target OTA Requestor. A Software Image from an attacker that crafts its own signed image and tries to have it accepted would be rejected since that image will not be signed by the Vendor's signing authority.

Since Software Images MAY contain software for multiple sub-components (e.g. main processor firmware, radio firmware, graphical/audio assets) which MAY each employ different code signing keys, Software Images SHOULD provide at least an overall authenticity and integrity validation for the entire image, regardless of how it is segmented.

Individual Vendors MAY augment the basic security and authenticity schemes provided by the Software Images and provide their own extensions within the payloads. Those extensions are outside the scope of the OTA Software Update Cluster.

Software Images MAY be encrypted with symmetric keys such that only those OTA Requestors that need to decrypt the Software Image have access to the key. This MAY be used to mask or obfuscate the contents of Software Images from intermediate network participants conveying the Software Images, while in transit and at rest. However, the security of this system is dependent on the security of all OTA Requestors that have access to the symmetric key and the method of storage of the final Software Image at rest on a given OTA Requestor. The schemes employed by different Vendors to encrypt the body of Software Images in transit and at rest, is outside of the scope of this specification.

11.20.5. Some special situations

With the mechanisms provided by this Cluster, roll-out of new Software Images applies equally to all OTA Requestors of matching a given <VendorID, ProductID> tuple, uniformly across the world. The subsections below describe two situations where finer-grained roll-out can be achieved for some regions or to distribute special non-standard versions.

11.20.5.1. Regional roll-out of Software Images

Some Manufacturers have a policy of rolling-out by region (i.e. set of countries), to provide worldwide release schedule differentiation, as well as to test roll-outs gradually, among other reasons. These regional roll-outs may only be feasible using manufacturer-specific schemes that are in addition to the common flows described in this cluster. Common recommended behavior (see [Section 11.20.3.3.2, "Conceptual algorithm for matching OTA Software Images applicable to a query"](#)) does not support regional roll-out since there does not exist a location tagging attribute in the [Distributed Compliance Ledger \(DCL\)](#). For regional rolls-outs prior to full roll-out, refer to the overall techniques described in [Section 11.20.5.2, "Roll-out of non-standard Software Images"](#).

11.20.5.2. Roll-out of non-standard Software Images

Many Manufacturers conduct field trials to test different versions of software (e.g. A/B-testing, beta